SBOM и лицензии сторонних компонентов (реестр отечественного ПО)

Параметр	Значение
Документ	SBOM и лицензии (документ 11 комплекта)
Версия	1.0
Дата	27.10.2026
Статус	Действует
Артефакты	`sbom/*.cdx.json` (CycloneDX 1.5), `docs/sbom/licenses-report.md` (автогенерируемый)

1. Назначение

Поддержание актуального состава сторонних компонентов (SBOM) и анализ лицензий для **регистрации системы в реестре отечественного ПО** (постановление Правительства РФ № 1236): при включении в реестр правообладатель подтверждает, что использование сторонних компонентов не противоречит типовым условиям и не обязывает раскрывать исходный код регистрируемого ПО.

2. Состав и генерация

Артефакт	Пакет	Генерация
`sbom/server.cdx.json`	`server/` (NestJS API)	`cd server && npm run sbom`
`sbom/web.cdx.json`	`web/` (Vue SPA)	`cd web && npm run sbom`
`docs/sbom/licenses-report.md`	сводно	`node scripts/license-report.mjs`

Всё вместе: `make sbom`. SBOM строится из `package-lock.json` (`--package-lock-only`) — состав детерминирован и воспроизводим (`--output-reproducible`), компоненты «сплющены» (`--flatten-components`). Формат — CycloneDX 1.5 (совместим с инструментарием Минцифры и коммерческими сканерами).

3. Классификация лицензий

Класс	Риск для реестра ОП	Политика
Разрешительные (MIT, Apache-2.0, BSD-2/3, ISC, 0BSD, WTFPL, BlueOak, CC0, PostgreSQL, составные OR/AND из них)	Низкий	Допускаются; указание авторства — в разделе «Сторонние компоненты» документации
Слабый copyleft (LGPL, MPL-2.0)	Средний	Допуск только с ревью технического лидера и записью в decisions.md; допустима динамическая линковка без раскрытия своего кода

Класс	Риск для реестра ОП	Политика
Сильный copyleft (GPL-2/3, AGPL)	Высокий	**Запрещены**: раскрытие исходников либо юридически неизбежно, либо спорно
Не определена	Высокий	Блокер слияния: заполнить fallback-таблицу в скрипте (лицензия по тексту LICENSE-файла) или отказаться от зависимости

4. Текущее состояние (v0.1.0)

- Компонентов: **691** уникальных `name@version` по двум пакетам; 14 различных лицензий.
- **Все лицензии — разрешительные.** Вердикт отчёта: препятствий для регистрации в реестре ОП не выявлено.
- Два компонента (`busboy` , `streamsearch` — транзитивные зависимости загрузки файлов) не имеют поля `license` в манифесте; их лицензия MIT установлена по тексту LICENSE-файла и зафиксирована в fallback-таблице скрипта (в отчёте помечены `*`). При обновлении их версий — ручная проверка.

Актуальные таблицы: `docs/sbom/licenses-report.md` (перегенерируется автоматически, не правится руками).

5. Конвейер и контроль

1. CI на каждый PR: генерация SBOM + отчёт; задание падает, если в отчёте появились лицензии со средним/высоким риском или неопределённые.
2. Артефакты SBOM публикуются как artifacts прогона (состав на каждый коммит).
3. Добавление зависимости: PR обязан содержать обновлённый `package-lock` , SBOM и отчёт; новая copyleft-зависимость — блокер.
4. Перед выпуском версии (merge в `main`): SBOM фиксируется в релизной заметке `docs/versions.md` (состав и вердикт).

6. Ответственность

- Владелец процесса — технический лидер.
- Автоматизация — CI (без ручного сопровождения).
- Юридическая интерпретация спорных лицензий — по запросу в юрдепартамент с приложением отчёта.

7. Порядок изменения классификатора

Новая лицензия добавляется в `LICENSE_CLASS` скрипта `scripts/license-report.mjs` с обоснованием в `docs/decisions.md` ; изменение политики раздела 3 — ревью технического лидера.